# ROSI e ponto de equilíbrio

Como comparar o custo de uma proteção adicional com a redução estimada de perdas, sob premissas explícitas.

**Material genérico.** Não usa respostas, cálculos ou dados de qualquer pessoa ou empresa. Não é diagnóstico, auditoria, certificação, previsão ou benchmark, e não é personalizado a partir das suas respostas.

## O que o tema significa

O retorno sobre investimento em segurança (ROSI) compara o benefício esperado de uma medida de proteção com o custo dela no mesmo período. O benefício é a redução estimada de perdas financeiras, e não um lucro realizado. O resultado só é tão confiável quanto as estimativas de perda, frequência, eficácia e custo que o alimentam.

A estimativa de perdas exige identificar e documentar os cenários de risco. O NIST IR 8286A Rev. 1, que trata da identificação e da estimativa de risco de segurança cibernética para a gestão de risco corporativo, é usado aqui somente como apoio para identificar e documentar cenários. Não fornece a fórmula de ROSI nem valida as estimativas de perda, de eficácia ou de custo.

## Método da ferramenta

ADAPTAÇÃO ROOT TRUST Simplificação com horizonte de 12 meses e hipóteses visíveis. Não é o modelo oficial de nenhuma instituição citada.

L = prejuízo por incidente × frequência anual esperada de incidentes com prejuízo (perda de referência, mantendo os controles atuais).

f = (12 – d) / 12, para prazo d em meses até a proteção estar efetiva (f = 0 quando d ≥ 12). Pressupõe que a perda L se distribui de modo uniforme ao longo do ano.

B = L × e × f, em que e é a redução estimada das perdas durante a operação efetiva (de 0% a 100%), considerada constante depois que a proteção entra em efeito.

ROSI = (B – C) / C × 100, para custo adicional C > 0 no período de 12 meses.

Redução de equilíbrio = C / (L × f) × 100, quando L × f > 0. Equilíbrio é ROSI de 0%.

Custo e perda precisam estar na mesma moeda e no mesmo horizonte. Valores desconhecidos não devem ser tratados como zero. Quando um dado essencial falta, o resultado correspondente não deve ser calculado.

## Limites

- O resultado depende inteiramente das premissas. Não representa economia realizada nem a postura de segurança da organização.
- Um percentual de ROSI positivo não recomenda contratar a proteção; um negativo não recomenda dispensá-la.
- Um equilíbrio acima de 100% indica que a redução necessária excede as perdas incluídas no cenário, e não deve ser truncado.
- O modelo analisa um cenário por vez e não soma riscos diferentes. Benefícios de outras proteções já existentes não são atribuídos à medida avaliada.
- Prazo de 12 meses ou mais significa que não há benefício dentro do horizonte.

## Próximos passos

1. Definir um único cenário de incidente e listar as perdas financeiras sem sobreposição entre elas.
2. Registrar a origem de cada estimativa: histórico próprio, cotação, referência externa ou hipótese declarada.
3. Comparar a operação atual com a proteção adicional, incluindo implantação, despesas e trabalho interno do período.
4. Revisar as premissas com quem responde pela área de segurança e pela área financeira antes de decidir.
5. Repetir a análise quando surgirem dados novos, como incidentes reais ou cotações formais.

## Perguntas de revisão

- Qual é o único cenário de incidente que esta análise cobre, e o que fica de fora dele?
- De onde vem cada estimativa de perda: histórico próprio, cotação, referência externa ou hipótese declarada?
- As perdas listadas estão na mesma moeda e no mesmo período de 12 meses, sem se sobrepor?
- Quais controles atuais foram mantidos na perda de referência?
- Em quanto tempo a proteção estaria efetiva, e o que condiciona esse prazo?
- Quem responde pela área de segurança e pela área financeira revisou as premissas?

## Ações por tema

- Registrar as premissas (perda, frequência, redução esperada, custo e prazo) em um documento único, com a origem de cada uma.
- Repetir o cálculo com valores mais baixos e mais altos para cada premissa incerta e comparar as conclusões.
- Combinar com as áreas de segurança e financeira uma data para revisar as estimativas com dados novos.
- Guardar a análise como registro da decisão, indicando que o resultado depende das premissas e não prevê perdas.

## Fontes consultadas


- REFERÊNCIA OFICIAL NIST. *Identifying and Estimating Cybersecurity Risk for Enterprise Risk Management* (NIST IR 8286A Rev. 1), dez/2025. csrc.nist.gov/pubs/ir/8286/a/r1/final

Consultada em 12/10/2026.


---

## Solicitar diagnóstico

No site da Root Trust, use o formulário “Solicitar diagnóstico” (Nome, Empresa e WhatsApp). A conversa inicial é gratuita e de qualificação, com retorno por ligação ou WhatsApp no próximo dia útil após o recebimento do pedido. Se preferir, escreva para contato@roottrust.com.br. Não é auditoria, não há agenda automática e não inclui relatório personalizado.